PROJECT 10 OF 10 | SOC ANALYST PORTFOLIO

IR Playbook: Responding to a Phishing Password Theft

How I wrote a step-by-step emergency plan for a fake-email attack, practised it like a fire drill, and fixed the four gaps the drill exposed.

Prepared by: Riyaz Shaik, SOC Analyst L1 | Report date: 04 October 2026 | Framework: NIST SP 800-61

1. Summary in Plain English

Think of a school fire drill. Nobody waits for a real fire to decide who calls the fire brigade or which door to use. This project is the same idea for a **fake email that steals a password**. I wrote the plan (called a *playbook*), walked through a pretend attack out loud (called a *tabletop exercise*), found where the plan was weak, and repaired it.

Result at a glance
What happened (simulated): A Finance employee clicked a fake Microsoft 365 email and typed their password.
What fired: Microsoft Defender alert "Sign-in from unfamiliar location" at 09:12.
My conclusion: Confirmed phishing AND confirmed account takeover. Severity: P1 - High.
Outcome: Contained by 10:10, under one hour after the alert. The drill found 4 playbook gaps, all fixed.

2. Words You Need (Simple Glossary)

Term	Simple meaning
Phishing	A fake email pretending to be a trusted company, designed to trick you into giving up your password.
NIST SP 800-61	A free official rulebook from the US government on how to handle security incidents. Used worldwide.
Playbook	A written, step-by-step plan: who does what, in what order, when an attack happens.
Tabletop exercise	A practice drill done by talking through a fake attack. No real computers are touched.
IOC	Indicator of Compromise: a clue that an attack happened, such as a bad link or sender address.
SPF / DKIM / DMARC	Three email "ID checks". If all three fail, the sender is probably not who they claim to be.
Defanged link	A dangerous link written safely, like micros0ft-verify[.]com, so nobody clicks it by accident.

3. The Environment I Used

This project was a **scenario-based exercise**, not a technical lab. There was no attack machine. The scenario, evidence and ticket are simulated, built to follow how a real SOC works. The tools and sources I worked with were:

Tool or source	What it is used for
Email security gateway	Shows when the phishing email arrived and lets the SOC block or remove it.
Proxy / web logs	Shows who clicked which link, and when.
Microsoft Defender and sign-in logs	Raised the alert and showed where the attacker logged in from.
URLScan.io	Safely opens a suspicious link in an isolated sandbox and takes a picture of it.
VirusTotal	Shows how many security vendors flag a link or domain as malicious.
Splunk and ticketing system	Where the SOC picks up alerts and records the work.
Active Directory / Microsoft 365 Admin Center	Used to disable the account and revoke sessions.
NIST SP 800-61	The framework: Preparation, Detection and Analysis, Containment/Eradication/Recovery, Post-Incident.

4. The Story: What Happened

Time	Event	Source
09:00	Phishing email arrives in a Finance employee's inbox	Email gateway
09:03	Employee clicks the link	Proxy / web logs
09:04	Employee types real password into a fake Microsoft page (inferred from timeline and user interview)	Inferred
09:12	ALERT: sign-in from an unfamiliar country, about 8 minutes after the password was typed	Microsoft Defender
09:15	I pick up the alert	Splunk / ticketing
09:20	Investigation begins	-
09:35	Containment starts	-
10:10	Incident contained	-

5. What I Checked, What I Found, and Why It Matters

Check	What I did	What I found	Why it matters
1. Email header	Compared the real sender with the displayed name and checked SPF, DKIM, DMARC	Domain micros0ft-verify[.]com (a zero instead of the letter o). SPF, DKIM and DMARC all FAILED.	A lookalike domain with all three ID checks failing is strong proof of a fake sender.
2. The link	Opened it safely in URLScan.io	An exact copy of the Microsoft 365 login page, on a domain less than 7 days old.	Brand-new domains imitating a famous brand are a classic phishing sign.
3. Reputation	Checked VirusTotal	34 of 70 vendors flagged it as malicious.	Independent confirmation, so it is not just my opinion.
4. Was the password used?	Reviewed Defender sign-in logs	Sign-in from a different country on a device never seen for this user.	Proves the attacker **used** the stolen password, not just collected it.

What I concluded and why
Conclusion: This is a real phishing attack that led to a real account takeover.
Why: (1) the email failed every authentication check, (2) the page was a fresh copy of the Microsoft login, (3) 34 of 70 vendors agree, and (4) the sign-in log shows the attacker actually logged in. Steps 1 to 3 prove phishing. Step 4 proves compromise.

6. Why I Rated It High Severity

Question	Answer
Was a real password typed in?	Yes
Did the attacker actually log in with it?	Yes (confirmed sign-in)
Can this account reach sensitive data?	Yes, it is a Finance account
Could it spread (shared mailbox, forwarded email)?	Possible, needs checking

If the password had been phished but never used, I would have rated it Medium. The **confirmed sign-in** is what moves it to High. The ticket (INC-2026-0417, P1 - High) records the IOCs: sender domain micros0ft-verify[.]com, link hxxps://micros0ft-verify[.]com/login, and the attacker's IP (anonymised).

7. What I Did: The Four NIST Phases

Phase	Actions	Why
1. Contain	Disable the account. Revoke all sessions and tokens. Block the link and sender domain at the email gateway and proxy. Tell the employee directly.	Stop the attacker first; every minute of access is risk.
2. Eradicate	Look for auto-forwarding rules in the mailbox. Check files shared or downloaded during the compromised window (09:12 to 09:20). Search the company for the same email and remove it.	Attackers hide a forwarding rule so they keep reading mail even after a password reset. Others were probably targeted too.
3. Recover	Reset the password. Re-enable and confirm MFA. Re-enable the account only after confirming no persistence. Monitor for 72 hours.	Return to normal without leaving a back door.
4. Lessons learned	Review how the email got through. Update filters for lookalike domains. Run awareness reminders. Update the playbook.	Make the next attack harder.

8. The Fire Drill: Tabletop Exercise Results

I read the scenario aloud and followed my own playbook step by step as the on-shift L1 analyst. The drill exposed problems that looked fine on paper:

Gap found during the drill	Fix added to the playbook
Nobody was named as allowed to disable an account. Does L1 need manager approval? (found at 09:18)	L1 has standing authority to disable any account with a confirmed compromised sign-in within the first 15 minutes, without waiting for approval.
No check for a mailbox auto-forwarding rule that keeps leaking mail after the password reset (found at 09:32)	Mandatory step: always check forwarding rules and inbox delegation BEFORE closing the incident.
No plan to tell the employee	Call the affected employee within 30 minutes. Never let them hear it through rumour.
No guidance on checking for spread	Before closing, search the whole company for the same subject or sender. Assume more than one person was targeted.

9. MITRE ATT&CK Mapping

Stage of the attack	Technique	ID	Tactic
Attacker registers lookalike domain	Acquire Infrastructure: Domains	T1583.001	Resource Development
Phishing email with a link	Phishing: Spearphishing Link	T1566.002	Initial Access
Employee clicks the link	User Execution: Malicious Link	T1204.001	Execution
Attacker logs in with stolen password	Valid Accounts	T1078	Initial Access / Persistence

10. What I Found in This Project (Key Findings)

- **A playbook that looks complete can still fail.** Four real gaps appeared within the first 20 minutes of the drill.
- **Phishing and compromise are different facts.** Only the sign-in log proves the attacker used the password, and that decides the severity.
- **The most dangerous gap was invisible:** a hidden forwarding rule would let the attacker keep reading email after the password reset.
- **Speed depends on clear authority.** If an analyst has to ask permission, minutes are lost while the attacker is active.

11. What I Would Improve

- **Run it with real people.** My tabletop was done alone. A real drill needs an L2 analyst, a manager, IT and HR so communication gaps show up.
- **Add timings and goals.** Set targets, for example contain within 30 minutes, and measure them each drill.
- **Automate the repetitive steps.** Revoking sessions, blocking the domain and searching for matching emails can be automated (SOAR) to save minutes.
- **Cover more scenarios:** an attacker who passes MFA, a user who only clicked but did not type a password, and a phishing email with a malicious attachment.
- **Use real timing evidence.** The 09:04 password entry was inferred; in a real case the proxy and sign-in logs should confirm it.

12. What I Actually Learned

- How to prove an email is fake using SPF, DKIM, DMARC and lookalike-domain checks.
- How to use free tools (URLScan.io, VirusTotal) to confirm a threat quickly and safely.
- How to justify a severity rating with simple yes/no questions, not gut feeling.
- That testing a plan is worth more than writing it, and that a tabletop is the cheapest way to find its weak points.

13. How This Connects to the Real World

Phishing aimed at Microsoft 365 logins is one of the most common ways attackers reach company email, and Finance staff are favourite targets because of payment authority. A hidden mailbox forwarding rule is a well-known trick used after account takeover, which is why my fix for it matters. Real companies and auditors expect written playbooks that follow NIST; this project follows the same method: investigate, classify, contain, eradicate, recover, learn.

14. Final Recommendations

Priority	Recommendation	Why
1	Enforce MFA on all accounts	This alone would have stopped the attacker from using the stolen password.
2	Update email filters to catch lookalike domains (0 for o, and similar)	Stops the email before anyone sees it.
3	Run phishing awareness training and simulated phishing tests every quarter	Reduces clicks over time.
4	Build an automatic SIEM alert for new mailbox forwarding rules	Catches the hidden back door quickly.
5	Repeat this tabletop every 6 months with a new scenario	Keeps the playbook alive and tested.

15. Conclusion

A simulated phishing attack was investigated and proven to be both a real phishing email and a real account takeover. It was rated High severity because the stolen password was actually used on a Finance account, and containment was completed in under an hour. The tabletop exercise was the most valuable part: it found four gaps in my own playbook (account-disable authority, forwarding rules, employee communication, and spread checks) and each one was fixed. The key message is simple: **MFA stops most of the damage, and a practised plan stops the rest.**

> **Honest limits of this report**
> The scenario, IOCs and ticket are simulated for learning, and the tabletop was run by one person. It shows the method and the thinking, but it is not a record of a real company incident.